RÉSEAU / CYBERSÉCURITÉ / ACCÈS DISTANTS

ZTNA

Zero Trust Network Access

Concevoir des accès sécurisés aux applications de l’entreprise

Dans une entreprise comme

Bouygues Construction

Principes, fonctionnement et architecture de référence

Cas d’usage : siège, télétravail, partenaires et chantiers

Cahier des charges : 48 exigences et 22 tests de recette

Migration VPN, exploitation et aide à la décision

PRÉPARÉ POUR

Rebecca BOSAKE

Version 1.0 / 21 octobre 2026 / approche indépendante des fournisseurs

ÉTUDE PÉDAGOGIQUE ET PROPOSITION DE CADRAGE

Ce dossier ne décrit pas le système réellement utilisé par Bouygues Construction.
Les architectures, volumes et objectifs sont des propositions à valider avec la DSI.
Aucun test de production, logo de l’entreprise ou secret interne n’est présenté.

SYNTHÈSE — LECTURE EN TROIS MINUTES

Le ZTNA : à quoi sert-il concrètement ?

La réponse courte
Le **Zero Trust Network Access** est une approche d'accès contrôlé aux applications : l'identité de la personne, l'état du terminal et le contexte servent à décider **quelle application elle peut atteindre**. On n'accorde pas un accès général au réseau simplement parce qu'elle est au bureau ou connectée à distance.

Question	Contrôle possible	Exemple de chantier
Qui demande ?	Identité et authentification forte.	Une collaboratrice du projet CH-042.
Depuis quel équipement ?	Conformité du poste et signaux de sécurité.	Ordinateur géré, protection active.
Pour quel service ?	Droit sur une application précise.	GED du projet, pas tout le SI.
Dans quel contexte ?	Durée, risque, horaires ou signal de session.	Accès temporaire d'un partenaire.

Le ZTNA est une **catégorie d'architecture et de produits**, pas le nom d'un fournisseur unique. Il peut être hébergé dans le cloud, dans l'entreprise ou de manière hybride. Le dossier reste volontairement indépendant des marques.

La valeur recherchée

- Réduire les accès trop larges et les déplacements latéraux.
- Donner aux salariés et partenaires le strict accès nécessaire.
- Tracer la décision et retirer rapidement les droits devenus inutiles.
- Accompagner la mobilité sans supprimer la sécurité applicative.

La limite essentielle
ZTNA n'est ni un antivirus, ni une sauvegarde, ni une garantie d'absence de fuite. Il ne répare pas une coupure Internet et ne remplace pas les permissions dans l'application.

NAVIGATION

Sommaire et parcours de lecture

Partie	Pages
Synthèse, cadre et besoins métier	2–5
Zero Trust, comparaison VPN et composants	6–10
Architecture et modes d’accès	11–13
Identité, posture et politiques	14–16
Applications, protocoles, OT et chantiers	17–21
DNS/AD/Infoblox, flux et sécurité	22–24
Continuité et dimensionnement	25–26
Déploiement, migration et exploitation	27–30
Cahier des charges : 48 exigences traçables	31–37
Recette : 22 tests attendus	38–39
Atelier de démonstration et diagnostic	40
Risques, consultation et budget	41–42
Lexique et références à vérifier	43
Fiche de présentation et prochaines décisions	44

Selon le public

Public	Parcours recommandé
Direction / sponsor	2, 5–8, 11, 21, 27, 31, 41–42, 44
Réseau / systèmes / sécurité	9–26, 28–30, 38–40
Chef de projet / achats	4, 17, 27–39, 41–43

Les signets permettent une navigation page par page. Les schémas sont originaux et illustratifs : ils ne représentent ni une console fournisseur ni un environnement de production.

01 — CADRE DE L'ÉTUDE

Faits techniques, hypothèses et inconnues

Ce dossier propose un environnement ZTNA pour **une entreprise comme Bouygues Construction**. Il ne prouve pas l'usage réel d'une solution, d'un fournisseur ou d'une architecture par cette entreprise.

Statut	Contenu
Principes techniques	Contrôle d'accès, identité, posture, points de décision et d'application.
Choix proposés	Accès aux applications, connecteurs redondés, politique de refus et pilote.
Hypothèses fictives	1 siège, 10 agences, 20 chantiers, 6 000 comptes humains et 1 200 sessions simultanées de travail.
Informations inconnues	Parc, applications, identité, contrats, fournisseurs, réseaux et objectifs réels.

Règles de lecture

- **Exemple** : donnée inventée pour expliquer ; pas une configuration à copier.
- **Exigence** : besoin à contractualiser, avec périmètre et preuve.
- **Résultat attendu** : test à exécuter ; aucun test n'est déjà réussi.
- **Option** : dépend des produits, versions, intégrations et licences.

> **Conventions**
> Les IP privées et les domaines **.example** sont illustratifs. Aucun compte, secret ou schéma interne n'a été fourni. Une politique décrite en pseudo-YAML page 40 n'est pas un fichier exploitable par un fournisseur.

Il n'y a pas d'accès de recherche web dans cette rédaction. Les références page 43 sont des pistes officielles à consulter, pas des sources vérifiées en ligne. Les offres, tarifs et règles juridiques actuels ne sont pas affirmés.

02 — BESOINS MÉTIER

Les usages dans une entreprise de construction

Situation type	Accès utile	Risque à réduire
Salarié mobile	GED, ERP ou portail interne depuis un poste géré.	Un accès VPN plus large que son besoin.
Équipe de chantier	Applications du projet depuis plusieurs accès WAN.	Droits conservés après la fin du projet.
Bureau d'études / BIM	Application et fichiers utiles aux maquettes.	Performance insuffisante ou protocole incompatible.
Sous-traitant	Portail ou application du seul projet autorisé.	Compte durable et visibilité sur d'autres projets.
Maintenance technique	Accès approuvé vers une cible, éventuellement par bastion.	Accès direct non contrôlé à un réseau technique.
Télétravail	Accès applicatif conforme aux mêmes politiques.	Confiance supposée dans le réseau domestique.

Le bon résultat métier

Une personne ouvre l'application autorisée, avec une expérience suffisamment fluide ; elle ne voit pas automatiquement les autres ressources. Le propriétaire du projet sait qui dispose de l'accès, pour quelle durée et selon quelle validation.

- Associer les métiers, systèmes, réseau, identité, sécurité et support.
- Inclure des sites à WAN contraint et des équipements représentatifs.
- Mesurer connexion, opérations applicatives et temps d'administration.

> **Ne pas confondre besoin et inventaire**
> Ces cas sont des exemples de construction multisite. Ils ne constituent ni la liste des applications ni l'organisation interne de Bouygues Construction.

03 — PRINCIPES ZERO TRUST

Ne pas accorder de confiance implicite

Zero Trust est une stratégie plus large que ZTNA. Le principe est de ne pas attribuer de confiance durable à une personne ou un équipement uniquement en raison de sa localisation réseau, de son propriétaire ou d'une ancienne connexion réussie.

Trois règles pour expliquer l'approche

1. Vérifier explicitement : identité, terminal, ressource et contexte, avec des signaux dont on connaît la fiabilité et la fraîcheur.

2. Limiter le privilège : autoriser la ressource utile et les actions nécessaires ; ne pas ouvrir un sous-réseau entier par commodité.

3. Préparer la dégradation : supposer qu'un compte ou poste peut être compromis ; limiter l'impact, observer et retirer les accès.

Affirmation courante	Correction importante
« Au siège, le poste est de confiance. »	La présence au siège n'est pas une preuve suffisante.
« La MFA suffit. »	Elle authentifie ; elle ne définit pas tous les droits et ne garantit pas un poste sain.
« On vérifie en permanence chaque paquet. »	La fréquence et les événements de réévaluation dépendent de l'architecture.
« ZTNA rend les applications inviolables. »	Les failles et permissions applicatives restent à traiter.

Réévaluation réaliste
La révocation peut dépendre de caches, de signaux reçus, de jetons et de sessions applicatives. Définir un délai maximal mesurable plutôt que promettre un arrêt immédiat universel.

03 — COMPARAISON

ZTNA et VPN : différents périmètres d’accès

Critère	VPN réseau classique	ZTNA orienté application
Ce qui est ouvert	Tunnel et routes vers un périmètre réseau défini.	Application et flux explicitement autorisés.
Décision	Identité, MFA, ACL et posture possibles selon le VPN.	Identité, posture et contexte selon le produit.
Visibilité réseau	Peut être large si routes/ACL le sont.	Peut réduire la visibilité des ressources non publiées.
Protocoles	Souvent large couverture IP, à filtrer.	Compatibilité à vérifier application par application.
Dépendances	Passerelle, réseau, identité et certificats.	Point d’accès, identité, connecteurs, client et signaux.
Migration	Architecture existante à connaître.	Progressive, avec coexistence et contrôle des contournements.

Ce n’est pas « VPN mauvais, ZTNA parfait »

Un VPN correctement segmenté avec MFA, filtrage et droits limités peut être solide. Un ZTNA mal configuré peut publier trop de destinations, accepter des signaux périmés ou laisser un chemin direct incontrôlé. Comparer les **contrôles réels**, pas seulement les labels.

Pourquoi garder temporairement un VPN ?

- Protocole non supporté, trafic de découverte ou flux bidirectionnel spécifique.
- Application fortement dépendante d’un réseau ou de services hérités.
- Périmètre technique dont la migration doit être validée séparément.

> **Coexistence contrôlée**
> Un VPN conservé comme exception doit être limité, surveillé et daté. Le laisser ouvrir tout le SI peut contourner les règles du ZTNA.

03 — SITUER LA SOLUTION

ZTNA, SSE, SASE, IAM et PAM

Brique	Rôle	Lien avec le projet
ZTNA	Accès contrôlé aux applications.	Sujet principal de ce dossier.
IAM / IdP	Identités, authentification, groupes et cycle de vie.	Fournit des signaux ; l'application garde ses permissions.
MDM/UEM et EDR	Gestion et protection du terminal.	Sources possibles de conformité et de risque.
SSE	Services de sécurité d'accès ; combinaison selon l'offre.	Peut regrouper ZTNA, SWG, CASB et autres fonctions.
SASE	Association d'accès réseau et de sécurité distribuée.	Peut inclure SD-WAN et SSE ; périmètre à vérifier.
SWG / CASB / DLP	Sécurité web, usages cloud et protection de données.	Compléments, pas inclus dans tout ZTNA.
PAM / bastion	Gestion des accès et secrets privilégiés.	Pour administration et maintenance sensibles.

Positionnement SaaS

Une application SaaS publique peut être protégée par l'identité, l'accès conditionnel et des contrôles CASB/SSE. Elle ne traverse pas nécessairement un connecteur ZTNA de l'entreprise. Vérifier le trajet réel, le périmètre de contrôle et les licences.

> **ZTNA n'est pas un produit unique**
> Plusieurs familles de fournisseurs existent. Ce document décrit des besoins et critères de preuve, sans affirmer que toutes les solutions couvrent agents, accès web, UDP, SaaS, PAM ou DLP de la même façon.

04 — COMPOSANTS

Les éléments d’un environnement ZTNA

Composant	Rôle	Point de vigilance
IdP et MFA	Authentifier et fournir groupes/attributs.	Disponibilité, jetons, synchronisation et révocation.
Source de posture	État MDM, EDR, certificat ou client.	Fiabilité, fraîcheur et terminal inconnu.
Décision de politique	Évaluer l’autorisation vers une ressource.	Priorités, caches, exceptions et audit.
Point d’application	Faire appliquer accès/refus sur le chemin prévu.	Tous les chemins pertinents doivent être maîtrisés.
Connecteur / passerelle	Relier les applications privées à l’accès contrôlé.	Capacité, zones, protocoles et privilèges minimaux.
Client ou navigateur	Démarrer l’accès selon le mode supporté.	OS, déploiement, cookies, compatibilité et BYOD.
SIEM et supervision	Recevoir événements et mesurer le service.	Horodatage, collecte utile et données sensibles.

Repères de l’architecture conceptuelle

Dans le modèle NIST, le **Policy Engine** prend la décision et le **Policy Administrator** aide à établir ou fermer la communication. Ils forment le point de décision au sens large. Le **Policy Enforcement Point** applique la décision. Ces rôles peuvent être répartis ou combinés dans un produit.

> **Plan de contrôle et plan de données**
> Le contrôle transporte identités, signaux et politiques. Le plan de données transporte les sessions applicatives. Une panne de gestion n’arrête pas forcément toute session ; une panne d’identité ne garantit pas non plus une continuité illimitée.

04 — FONCTIONNEMENT

Le parcours d’une demande d’accès

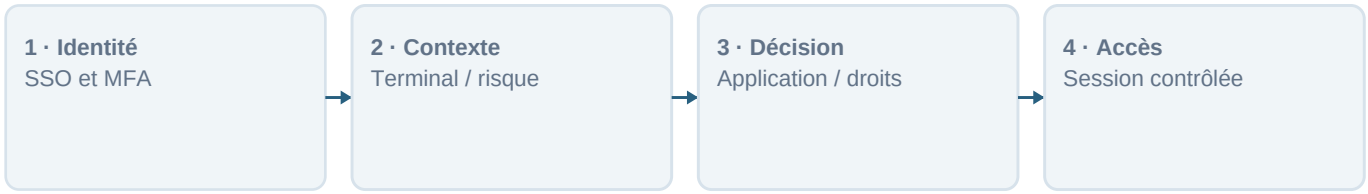


Illustration 1 — Parcours logique, pas description d’un protocole fournisseur.

1. Le client ou le navigateur rejoint le point d’accès prévu et redirige vers l’identité si nécessaire.

2. L’IdP authentifie selon sa politique. Un jeton ou une assertion prouve un résultat d’authentification ; ce n’est pas un droit universel.

3. Les signaux de terminal et de contexte sont évalués : géré ou non, protection active, signal récent, niveau d’authentification.

4. La règle applicable détermine la ressource autorisée et la durée/les conditions de la session. Le refus est le comportement prévu en l’absence de règle valide.

5. Le point d’application et les connecteurs, lorsqu’ils sont utilisés, établissent le chemin vers la seule ressource permise.

6. Les événements et réévaluations supportés permettent de limiter ou fermer l’accès. La session de l’application elle-même doit aussi être prise en compte.

Exemple

La collaboratrice du projet CH-042, depuis un poste conforme avec MFA, peut ouvrir la GED du projet en HTTPS. Le même compte ne reçoit pas pour autant le droit de joindre une interface d’administration, un partage d’un autre projet ou un réseau technique.

> **L’application garde sa sécurité**
> ZTNA peut ouvrir le chemin. La GED doit encore appliquer ses rôles : lire, écrire, partager ou administrer. Sans ce contrôle, un accès autorisé peut rester trop puissant.

05 — ARCHITECTURE ILLUSTRATIVE

Un accès contrôlé vers les applications privées

Proposition : identités centralisées, décisions explicites, accès distribué et connecteurs séparés par zone applicative. Les rôles, hébergements et liens sont à confirmer avec le fournisseur retenu.

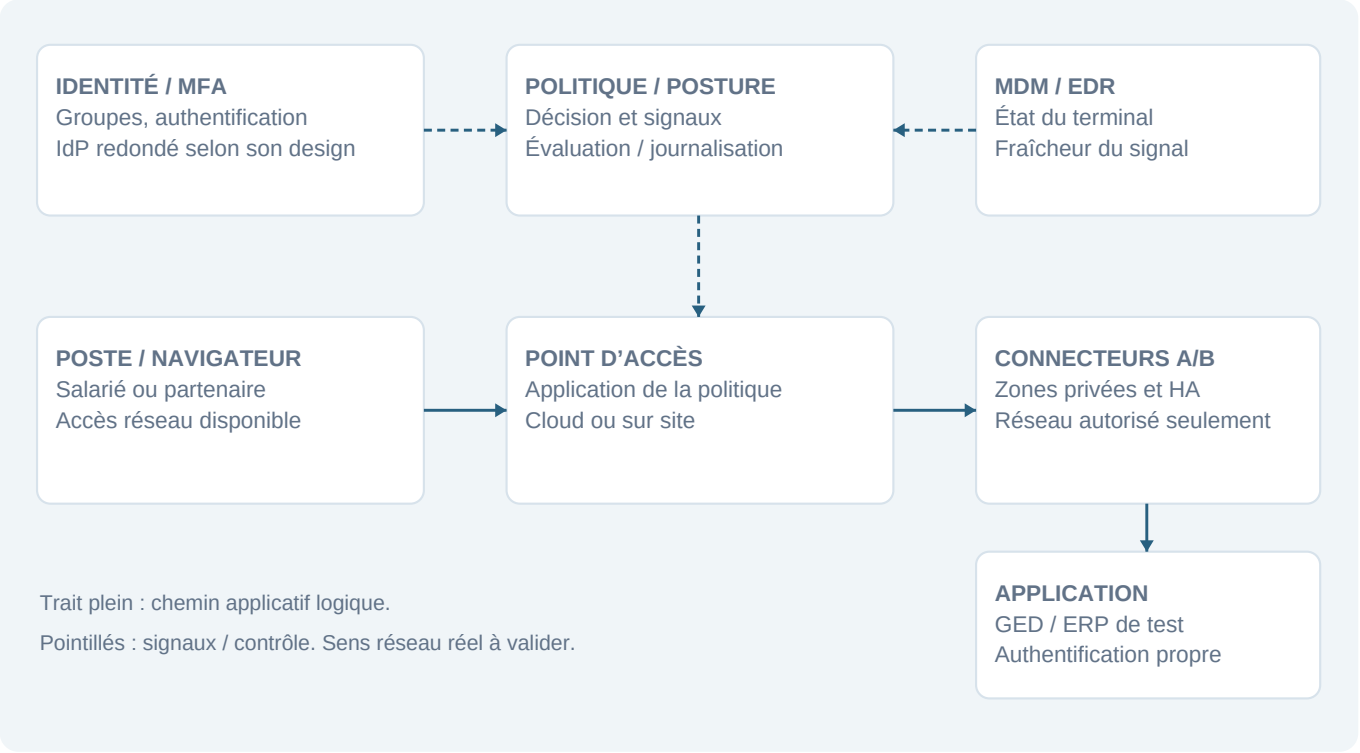


Illustration 2 — Schéma original, non interne à Bouygues Construction. Une connexion sortante du connecteur peut porter le retour applicatif : les flèches ne sont pas une matrice de ports.

- Au moins deux connecteurs lorsque la criticité l'exige, sur des domaines de panne distincts.
- Destination applicative restreinte ; ne pas publier automatiquement toute une zone réseau.
- Trajet, terminaison TLS et lieux de traitement clairement documentés.

> **Indépendance des chemins**
> Un accès direct local, public ou VPN peut contourner le point d'application s'il reste ouvert. La sécurité réseau et applicative doit fermer ou maîtriser ces chemins.

05 — HÉBERGEMENT

Cloud, sur site ou hybride : arbitrer les dépendances

Mode	Avantages possibles	Contraintes à vérifier
Service cloud	Accès distribué, exploitation partagée avec le fournisseur.	Internet, localisation, résilience du service, contrat et visibilité.
Sur site	Contrôle de l'hébergement et de certains flux locaux.	Capacité, accès extérieur sécurisé, mises à jour et exploitation interne.
Hybride	Adaptation des trajets aux sites et applications.	Complexité, cohérence des règles et comportements en panne.

Questions de choix

- Où sont utilisateurs, applications, connecteurs et points d'accès ?
- Le trafic applicatif est-il relayé, proxifié ou direct après contrôle ?
- Quel fournisseur voit les données, déchiffre TLS ou conserve les logs ?
- Que se passe-t-il si un point d'accès, l'IdP ou le cloud est indisponible ?
- Quel service peut encore fonctionner localement sans Internet ?

Un déploiement sur site ne garantit pas l'autonomie : il peut dépendre d'un IdP, d'une licence ou d'une console cloud. Un service cloud peut proposer plusieurs chemins, mais il faut en prouver le fonctionnement au pilote.

> **Pas de choix implicite de fournisseur**
> Le cahier des charges impose des preuves et des tests sur les scénarios réels. Les options commerciales, les garanties de service et la couverture géographique doivent être vérifiées au moment de la consultation.

05 — MODES D’ACCÈS

Client installé, navigateur et postes non gérés

Mode	Usage envisageable	Limite à valider
Agent sur poste géré	Accès aux applications web et autres protocoles supportés.	OS, privilèges d’installation, MDM, conflit VPN/proxy et mises à jour.
Accès web sans agent	Portail ou reverse proxy pour certaines applications HTTP(S).	Compatibilité navigateur, redirects, cookies, SSO et restrictions réelles.
Poste partenaire / BYOD	Accès réduit selon identité, risque et capacités disponibles.	On ne connaît pas forcément toute la posture du terminal.
Accès distant isolé	Navigation isolée ou environnement virtuel selon les options.	Produit complémentaire, ergonomie, coût et transferts de données.

Ce qu’un navigateur seul ne promet pas

- Un contrôle complet de l’EDR ou des correctifs du poste personnel.
- La prise en charge de SMB, d’un client lourd ou de tout protocole IP.
- L’impossibilité de copier, photographier ou divulguer une donnée affichée.

Politique BYOD proposée
Par défaut, limiter le poste non géré à des applications et opérations explicitement approuvées. Si « lecture seule » est demandée, la prouver dans l’application ou le mécanisme complémentaire ; le simple accès ZTNA ne suffit pas.

Prévoir compatibilité mobile, accessibilité et usages sans poste dédié. La validation doit couvrir l’expérience métier et les risques, pas seulement l’écran de connexion.

06 — IDENTITÉ

SSO, MFA et cycle de vie des comptes

Le ZTNA s’appuie généralement sur un fournisseur d’identité. SAML ou OpenID Connect peuvent transporter l’authentification selon le produit. La fédération ne supprime pas la gestion des comptes, groupes et droits dans les systèmes concernés.

1. Créer : associer le compte à une personne, un responsable et un statut salarié/partenaire.

2. Autoriser : attribuer un groupe ou attribut de projet après approbation du propriétaire.

3. Authentifier : imposer une MFA adaptée au risque ; privilégier des méthodes résistantes au hameçonnage lorsqu’elles sont supportées.

4. Réviser : vérifier périodiquement projet, durée et privilèges. Un changement de poste doit enlever les anciens accès.

5. Retirer : désactiver le compte, révoquer les jetons/sessions pertinents et vérifier les sessions applicatives.

Identité	Traitement proposé
Salarié	Compte nominatif, groupe métier et terminal géré.
Partenaire	Sponsor interne, ressource précise et date d’expiration.
Administrateur	Identité dédiée, privilège temporaire si possible et PAM selon le besoin.
Automate / service	Identité non humaine distincte ; mécanisme supporté et rotation des secrets.

> **Révocation à prouver**
> Un compte désactivé peut encore avoir une session ou un cookie actif selon le système. Mesurer le délai de blocage ZTNA ET celui des usages applicatifs ; ne pas confondre expiration du jeton et fermeture de toute session.

06 — POSTURE DU TERMINAL

Évaluer un état utile, récent et fiable

Signal	Interprétation possible	Vigilance
Terminal géré	Enrôlé auprès du MDM/UEM.	L'enrôlement ne prouve pas seul l'état de sécurité.
Version / correctifs	Respect d'une référence définie.	Exceptions, changement de version et cadence de collecte.
EDR actif	Protection et état remontés.	Service présent, santé, risque et signal récent.
Chiffrement / certificat	Protection locale ou preuve liée au terminal.	Support OS, certificat expiré et identité du poste.
Risque de session	Événement d'identité ou de sécurité.	Fiabilité, faux positifs et décision proportionnée.

Un signal absent est différent d'un signal conforme

Définir les états **conforme**, **non conforme**, **inconnu** et **périmé**. Une collecte arrêtée ne doit pas faire accepter indéfiniment la dernière réponse « conforme ». Documenter la durée de validité, les caches et la réaction en cours de session.

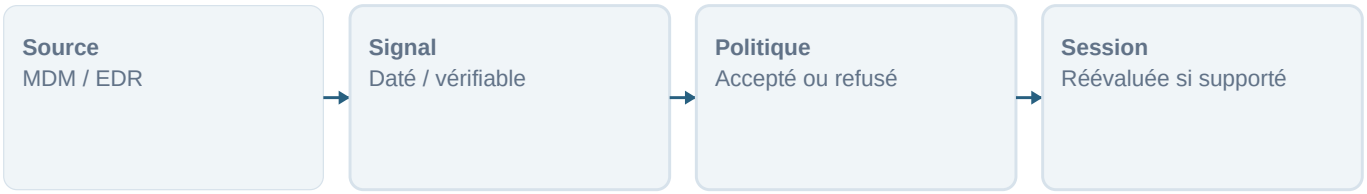


Illustration 3 — Le délai total inclut la collecte, la propagation et l'application de la règle.

Confidentialité de la posture
Collecter le minimum utile. Sur un terminal personnel, expliquer les informations réellement visibles et ne pas exiger une surveillance générale non justifiée. La conservation et les accès doivent être validés.

06 — POLITIQUES

Exemple de règles d’accès pour CH-042

Les règles ci-dessous sont **fictives**. Leur ordre et leur résolution doivent être définis selon le moteur retenu, puis testés avec des cas positifs et négatifs.

Cas	Conditions proposées	Résultat attendu
Compte bloqué ou accès expiré	Identité inactive, projet terminé ou droit révoqué.	Refus de nouvel accès ; fermeture selon délai validé.
Salarié du projet	Groupe CH-042, MFA appropriée, poste conforme récent.	Accès à la GED du projet en HTTPS seulement.
Partenaire autorisé	Compte nominatif sponsorisé, MFA, échéance valide.	Portail web précis ; droits internes de l’application limités.
Administrateur	Identité dédiée, MFA forte, poste d’administration, approbation.	Bastion ou cible précise, avec contrôle PAM si retenu.
Poste inconnu ou posture périmée	Preuve insuffisante pour le niveau demandé.	Refus ou accès réduit explicitement approuvé.
Aucune règle valable	Ressource non publiée ou conditions non satisfaites.	Refus par défaut.

Paramètres à fixer avant toute production

- Priorité entre règles et exceptions ; pas d’autorisation générique qui masque un refus.
- Ressource, protocole, ports, groupe, qualité de MFA et état du terminal.
- Durée d’accès, réévaluation, révocation et journal de décision.
- Date de retrait, propriétaire et justification de chaque exception.

> **Permission applicative distincte**
> Le groupe ZTNA « GED-CH042 » autorise le chemin. Les rôles lecture/écriture de la GED doivent aussi être corrects. Tester l’accès interdit à un autre projet et à une fonction d’administration.

07 — APPLICATIONS

Inventorier avant de publier

Champ à relever	Pourquoi
Nom et propriétaire	Savoir qui approuve le droit et valide la recette.
Hébergement et dépendances	Serveur, cloud, DNS, identité, base et services annexes.
Clients et protocoles	Navigateur, client lourd, TCP/UDP, ports et flux retour.
Authentification / rôles	SSO, compte local, Kerberos, durée des sessions et permissions.
Flux de données	Fichiers, téléchargements, volumes, sens et sensibilité.
Criticité / performance	Usages métier, délais, disponibilité et mode dégradé.
Chemins alternatifs	Public, local, VPN, mobile ou outils d’administration.

Fiche d’application de démonstration

GED-CH042 : application HTTPS fictive, nom ged.ch042.construction.example, propriétaire projet, utilisateurs salariés et partenaires. Les connecteurs ne doivent atteindre que les destinations nécessaires. L’authentification applicative, les liens externes et le téléchargement font partie de la recette.

> **Publier une application, pas tout son environnement**
> Une base de données située derrière la GED ne doit pas devenir joignable par l’utilisateur si seul le serveur applicatif en a besoin. Les dépendances serveur-serveur restent dans leur propre architecture.

Un inventaire incomplet peut faire apparaître une incompatibilité tardive, ou conduire à ouvrir beaucoup trop de destinations pour « que cela marche ». Prévoir un pilote par famille d’application.

07 — APPLICATIONS WEB

HTTPS, SSO et sessions : dessiner le trajet réel

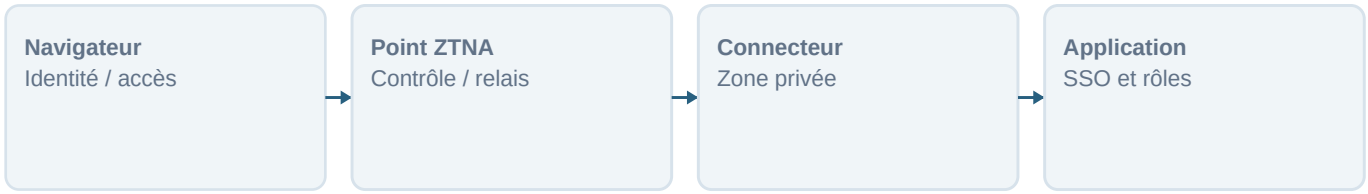


Illustration 4 — Trajet possible ; toutes les solutions web n’utilisent pas exactement ce chemin.

Vérifications indispensables

- Nom FQDN présenté au client, résolution DNS et certificat correspondant.
- Lieu de terminaison TLS et éventuel déchiffrement : qui voit le contenu ?
- Nouvelle liaison chiffrée vers l’application lorsque le design l’exige.
- Redirections, cookies, WebSocket, téléchargements et authentification SSO.
- En-têtes d’identité : ne pas faire confiance à un en-tête que le client peut injecter.
- Accès direct à l’origine : filtrer ou valider indépendamment, sans contournement.

Problème possible	Contrôle à réaliser
Boucle de connexion	Comparer URL de retour, SSO, cookie, proxy et domaine.
Certificat non valide	Chaîne, FQDN, expiration et confiance du poste/connecteur.
Application ouverte sans ZTNA	Essayer le chemin direct autorisé pour le test ; corriger réseau et identité.
Session conservée après retrait	Tester cookie applicatif, jetons et fermeture réellement appliquée.

Chiffrement par segment
« Tunnel chiffré » ne signifie pas automatiquement chiffrement de bout en bout sans intermédiaire. Documenter chacun des segments, la confiance TLS et les droits du service sur les données.

07 — APPLICATIONS NON WEB

BIM, fichiers et protocoles hérités

Famille	Besoin de recette	Risque d’hypothèse
Client BIM / CAO	Ouverture, synchronisation et transfert réel de maquettes.	Bonne connexion mais performance de fichier insuffisante.
Partage SMB	DNS, identité, ports, lecture/écriture et volume réel.	Support réseau ou authentification incomplets.
RDP / SSH	Cible précise, terminal, session et rôle d’administration.	Accès trop large ou absence de contrôle privilégié.
ERP / client lourd	Ports fixes/dynamiques et services secondaires.	Publier un port sans ses dépendances métier.
Voix / vidéo / UDP	Transport, NAT, débit, gigue et trajet réel si inclus.	Le fournisseur ne supporte pas tous les flux requis.
Découverte locale	Broadcast, multicast et service initié par le serveur.	ZTNA applicatif pas équivalent à un LAN étendu.

Une approche graduée

1. Mesurer les usages et les flux en laboratoire autorisé.

2. Vérifier le support contractuel du protocole et du sens de communication.

3. Tester les opérations lourdes, pas seulement l’ouverture de session.

4. Si incompatible, conserver une exception segmentée ou modifier l’architecture applicative.

> **ZTNA n’est pas une promesse universelle IP**
> Tous les produits ne gèrent pas UDP, ports dynamiques, connexions initiées par le serveur ou services de domaine de la même façon. Ne pas retirer le VPN avant une preuve représentative.

07 — PARTENAIRES ET RÉSEAUX TECHNIQUES

Maintenance, PAM et environnement OT

Un accès partenaire doit avoir un **sponsor interne**, une cible, un usage, une échéance et un mécanisme de retrait. L'accès technique ou OT exige une validation spécifique du propriétaire et des équipes sécurité/exploitation.

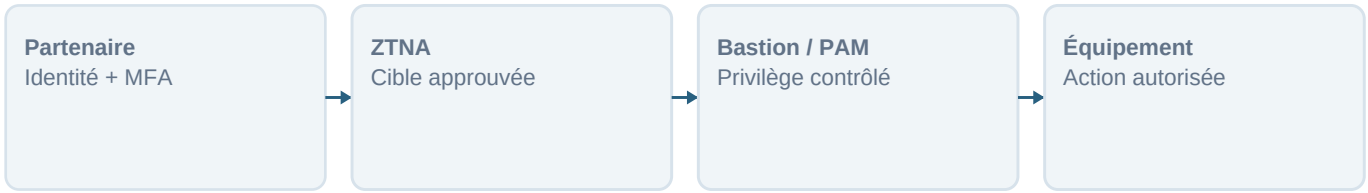


Illustration 5 — Combinaison possible ; PAM, bastion et enregistrement de session ne sont pas inclus dans tout ZTNA.

Garde-fous proposés

- Fenêtre de maintenance, approbation et compte nominatif.
- Cible précise ; pas de publication générale du réseau industriel.
- Secret injecté ou contrôlé par PAM lorsque le besoin le justifie.
- Journal et éventuel enregistrement de session si supporté et approuvé.
- Accès au poste d'ingénierie ou au bastion plutôt qu'à toutes les machines.
- Fin automatique du droit, vérification du retrait et procédure d'urgence.

Périmètre	Décision de cadrage
Maintenance bureautique	Pilote ZTNA/PAM avec scénario et compte dédiés.
Équipement OT critique	Analyse de sûreté, protocole et exploitation ; exclure si non validé.
Flux machine-machine	Architecture de workload distincte ; pas de MFA humaine imposée artificiellement.

Priorité à la sûreté et à la continuité
Ne pas provoquer un test de coupure sur un équipement critique sans environnement dédié et autorisation. Les essais ZTNA de ce dossier ne justifient aucune action sur un réseau technique réel.

07 — CHANTIERS ET WAN

Internet indisponible : les vraies limites

Situation	Effet possible	Réponse à étudier
Perte du lien Internet	IdP, cloud ZTNA ou applications distantes injoignables.	Second lien, SD-WAN ou accès local explicitement conçu.
WAN instable	Reconnexion, latence, perte de session.	Mesures multi-opérateurs et tests d’usage.
IdP inaccessible	Nouvelle authentification impossible ; sessions variables.	Résilience identité et comportement de cache testé.
Posture non reçue	Signal inconnu ou périmé.	Refus/accès réduit approuvé, sans fail-open général.
Application locale critique	Elle peut être saine mais son contrôle d’accès dépendre du cloud.	Conception locale compatible et procédure validée.

Le mode isolé n’est pas automatique

Un connecteur local ne suffit pas à garantir l’accès sans Internet. Les politiques, l’identité, les clés, les jetons et le point d’application peuvent rester distants. Les sessions existantes peuvent continuer ou échouer selon le produit ; tester aussi une personne sans session préexistante.

> **Pas de contournement par facilité**
> Définir un comportement de refus sûr pour les nouveaux accès non validables. Une procédure de continuité doit être limitée, approuvée, datée et traçable ; elle ne doit pas ouvrir silencieusement tout le réseau.

Pour CH-042, tester lien principal perdu, lien de secours, IdP indisponible et retour nominal. Mesurer chaque usage local/distant et vérifier qu’aucun accès interdit ne devient possible.

08 — INTÉGRATIONS DDI ET AD

Le lien avec Infoblox, DNS et Active Directory

Infoblox et ZTNA sont **complémentaires**. DDI fournit noms, paramètres réseau et référentiel IP ; ZTNA décide et fait appliquer un accès applicatif. Aucun des deux ne remplace le rôle de l'autre.

Brique	Rôle dans l'environnement	Contrôle d'intégration
DNS / Infoblox	Résolution des applications et dépendances ; politique DNS selon option.	FQDN, vues, transferts, cache et absence de fuite de noms internes.
DHCP / IPAM	Paramètres IP et contexte d'équipement/site.	Un bail ou une IP n'est pas une preuve d'identité forte.
Active Directory	Identités/groupes et certaines dépendances DNS/Kerberos.	Synchronisation IdP, appartenance et délais de retrait.
IdP fédéré	SSO/MFA et assertions.	AD n'est pas automatiquement l'IdP Internet direct.
ZTNA	Publication et décisions par application.	Règles de nom, transport et résolution du client/connecteur.

La résolution n'est pas toujours identique côté client

Selon le produit, le client peut recevoir une réponse interceptée/synthétique, utiliser un proxy ou une résolution classique. Le connecteur doit résoudre la destination selon le design. Ne pas publier une application en copiant seulement son IP dans un fichier local.

> **Accès aux services de domaine**
> Un accès ZTNA à la GED ne rend pas automatiquement disponibles jonction au domaine, GPO, Kerberos ou mises à jour du poste. Identifier leurs besoins et les traiter par les mécanismes supportés.

08 — RÉSEAU ET CERTIFICATS

Matrice de flux : version et topologie font foi

Flux logique	Repère usuel	À vérifier pour le produit
Client vers accès / IdP	HTTPS TCP 443 fréquent.	FQDN, endpoints, proxy, redirections et transports supplémentaires.
Connecteur vers service	TLS sortant fréquent.	Ports exacts, destinations, maintien de session, UDP/QUIC éventuel.
Connecteur vers application	HTTPS 443 ou ports propres à l'application.	Cibles strictes, dépendances et sens réel du flux.
DNS / temps	UDP/TCP 53 ; NTP UDP 123 si utilisés.	Résolveurs, synchronisation et sources autorisées.
Logs / API / posture	HTTPS ou transport de collecte supporté.	Authentification, certificats, lieux et minimisation.
Gestion / mises à jour	Flux fournisseur spécifiques.	Accès limité, signature, cache/proxy et procédure de panne.

Principe de restriction

Documenter source, destination, protocole, port, finalité, propriétaire et durée. Éviter une règle « connecteur vers tout le réseau ». Placer les connecteurs dans des zones adaptées et contrôler leurs accès de gestion.

> **Sortant ne signifie pas sans risque**
> Une connexion sortante peut porter un tunnel bidirectionnel. La compromission d'un connecteur peut exposer ses destinations accessibles. Restreindre ses privilèges, durcir l'hôte et surveiller les flux.

Le port 443 seul n'est pas une matrice finale. Inspection TLS, pinning, mTLS, autorités de confiance, expiration et rotation des certificats doivent être compatibles avec la documentation du produit.

09 — SÉCURITÉ ET DONNÉES

Ce que ZTNA protège, et ce qui reste à protéger

Socle de contrôles

- Refus par défaut ; groupes et ressources précis ; exceptions revues.
- MFA adaptée, identités privilégiées distinctes et droits limités.
- Signaux de posture frais et traitement explicite des états inconnus.
- Connecteurs durcis, à jour et limités à leur zone.
- Administration protégée, API à privilège minimal et secrets hors scripts.
- Audit de l’auteur, de la règle appliquée, du résultat et de la ressource.

Risque résiduel	Mesure complémentaire
Compte compromis malgré la MFA	Méthode résistante au hameçonnage, détection et révocation.
Application vulnérable	Correctifs, tests applicatifs et contrôle de ses permissions.
Utilisateur autorisé qui copie des données	Gouvernance, DLP/CASB ou restrictions applicatives si retenues.
Chemin direct hors ZTNA	Filtrage, identité applicative et test de contournement.
Console ou connecteur compromis	Durcissement, segmentation, moindre privilège et réponse incident.

> **Les journaux sont sensibles**
> Identités, applications, heures, adresses et signaux de terminal peuvent révéler activités ou projets. Définir accès, finalité, rétention, localisation et suppression avec RSSI/DPO/juridique. Aucune durée légale universelle n’est inventée ici.

Toute capacité d’inspection, de blocage de téléchargement ou d’enregistrement doit être confirmée dans le produit ou le complément retenu et validée au regard des usages.

10 — CONTINUITÉ

Disponibilité, sauvegarde et PRA

La redondance traite certaines pannes ; la sauvegarde traite la perte de configuration ; le PRA organise la reprise. Le service dépend aussi d'identité, de réseau, de DNS, de certificats et de posture.

Objectif proposé	Cible de travail	Preuve requise
Accès aux applications pilotes	99,95 % sur un mois de 30 jours.	Sondes par site, applications et fenêtres définies.
Reprise d'un composant critique	RTO inférieur ou égal à 30 min.	Panne de connecteur/point d'accès et reprise testées.
Configuration / règles	RPO inférieur ou égal à 4 h.	Version/export/backup, puis restauration contrôlée.
Révocation d'accès	Délai cible inférieur ou égal à 5 min.	De l'événement autoritatif au refus effectif, caches et sessions compris.

Toutes ces valeurs sont des **propositions à valider**, pas des garanties fournisseur. À 99,95 % sur 30 jours, le budget d'indisponibilité est d'environ **21,6 minutes**. Définir comment sont comptées maintenance et pannes d'IdP/WAN.

Tests de panne à prévoir

- Perte de connecteur, zone d'hébergement et point d'accès.
- Indisponibilité IdP, posture, DNS ou WAN de chantier.
- Restauration des règles, certificats et dépendances de confiance.
- Retour nominal sans droit élargi ni ancien accès réactivé.

> **Le refus sûr doit être explicite**
> Décrire nouveaux accès, sessions existantes et modes de cache séparément. Pas de fail-open général en cas de dépendance perdue. La continuité métier doit être conçue avec une procédure approuvée.

10 — DIMENSIONNEMENT

Mesurer sessions, flux et opérations métier

Hypothèse fictive : 6 000 comptes, 1 200 sessions simultanées et 20 chantiers. Ces valeurs ne décrivent pas le parc réel. Une session utilisateur peut produire plusieurs connexions et flux.

Mesure à collecter	Pourquoi
Utilisateurs et sessions simultanées	Capacité identité, licence et points d'accès.
Connexions par seconde et flux actifs	Rafales de début de journée et limites techniques.
Débit / fichiers / latence	GED, maquettes BIM et transferts volumineux.
Inspection et chiffrement	Coût de traitements si fonctions activées.
Répartition des sites et applications	Trajets, proximité et domaines de panne.
Logs et posture	Volume de collecte, conservation et fréquence.

Exemple de calcul, pas une référence commerciale

```
1 200 sessions x 0,5 Mbit/s moyen = 600 Mbit/s
Facteur de pointe suppose : 2 -> 1 200 Mbit/s
Marge proposee : 30 % -> 1 560 Mbit/s
Capacite survivante apres panne : a tester sur ce profil
```

La moyenne 0,5 Mbit/s et le facteur 2 sont inventés. Un fichier BIM ou une inspection peut changer le profil. Avec deux connecteurs partageant une charge, le survivant doit tenir la pointe prévue, pas seulement sa moitié habituelle.

> **Performance de bout en bout**
> Mesurer authentification, première ouverture et opérations applicatives. La latence du tunnel seule ne prouve pas une bonne synchronisation de fichiers. Les métriques de licence et limites de session sont à vérifier.

11 — DÉPLOIEMENT

Un pilote progressif, avec critères de sortie

Phase	Travaux	Jalon attendu
Cadrage : S1–S2	Inventaire, risques, identité, posture, besoins métiers.	Périmètre et responsables validés.
Conception : S3–S4	Architecture, licences, flux, politiques et recette.	Design supporté et budget approuvé.
Laboratoire : S5–S6	Web, client lourd, identité, posture et pannes.	Preuves techniques et rollback.
Pilote : S7–S9	Site permanent, chantier et partenaires représentatifs.	Usages métier et contrôles validés.
Stabilisation : S10–S11	Corrections, charge, formation, PRA et support.	Recette sans anomalie bloquante.
Décision : S12	Bilan, TCO, vagues et exceptions.	Go/no-go pour l'extension.

Ce calendrier de **12 semaines** est illustratif pour un cadrage et pilote, pas une promesse de déploiement global. Achats, intégrations et compatibilités peuvent modifier le délai.

Choisir un vrai pilote

- Un compte salarié, un partenaire et une identité privilégiée.
- Un poste conforme, un poste non conforme et un terminal inconnu.
- Une application web et une application lourde représentative.
- Un WAN dégradé, une panne de connecteur et un retrait de droits.

> **Conditions avant production**
> Aucune bascule sans propriétaire d'application, preuve de compatibilité, support, droits validés, backups et retour arrière. Un écran de connexion réussi ne valide pas tout le service.

11 — MIGRATION DEPUIS LE VPN

Coexister sans laisser un chemin de contournement

1. Inventorier VPN, routes, ACL, groupes, profils et usages réellement nécessaires.

2. Publier un premier périmètre applicatif ZTNA en laboratoire ; tester identité, posture, fonctions métier et sessions.

3. Déployer le client ou le mode web à un groupe pilote ; traiter conflits d'agent, DNS, proxy et certificats.

4. Limiter le VPN des personnes migrées aux seules exceptions justifiées ; ne pas laisser une route générale équivalente au SI.

5. Tester les chemins alternatifs : origine publique, accès local, VPN résiduel et mobile.

6. Retirer progressivement les exceptions après recette ; formaliser celles qui restent incompatibles.

Retour arrière limité au besoin

Définir déclencheur, responsable, durée et procédure. Revenir à un chemin **segmenté et approuvé**, pas rétablir une confiance globale. Documenter les changements de DNS, routes, agent, groupes et politiques afin de revenir à un état connu.

Critère de bascule	Preuve
Fonctions métier	Opérations représentatives, volumétrie et performances.
Sécurité	Cas interdits refusés ; pas de chemin direct non maîtrisé.
Support	Runbooks, visibilité, escalade et utilisateurs informés.
Réversibilité	Retour contrôlé testé et droits revus.

> **Ne pas désactiver tout le VPN au départ**
> Certains protocoles ou fonctions restent hors périmètre. Les conserver temporairement de façon restreinte, visible et datée est préférable à une migration sans preuve.

12 — EXPLOITATION

Responsabilités et cycle de vie des accès

R réalise ; **A** est responsable final ; **C/I** consulté/informé. Cette répartition est proposée et doit être alignée sur l'organisation réelle.

Activité	R	A	C / I
Identités / départs	IAM	Resp. identité	RH, sponsor projet
Politique / posture	Sécurité + IAM	RSSI	MDM/EDR, métiers
Publication applicative	ZTNA / réseau	Resp. service ZTNA	Propriétaire application
Droits de projet	IAM / opérateur	Propriétaire projet	Sponsor partenaire
Panne et reprise	Exploitation	Resp. service	Identité, réseau, fournisseur
Recette / production	Projet + équipes	Sponsor DSI	Métiers, sécurité, support

Runbook : donner un accès partenaire

1. Recevoir cible, personne, sponsor, usage, fenêtre et date de fin.

2. Valider sensibilité, mode d'accès et permissions dans l'application.

3. Créer identité/droits via le workflow approuvé ; vérifier MFA et terminal.

4. Tester cas permis et interdit ; enregistrer ticket et preuve.

5. À échéance, retirer droits et sessions, puis vérifier le retrait effectif.

> **Urgence et compte de secours**
> Prévoir une procédure contrôlée, avec protection forte, durée courte, accès ciblé, audit et revue après usage. Le compte de secours ne devient pas une exception permanente aux politiques.

12 — SUPERVISION ET INCIDENTS

Mesurer et diagnostiquer la chaîne complète

Symptôme	Premiers contrôles
Impossible de s’authentifier	IdP, MFA, heure, certificat, navigateur et compte.
Authentifié mais refusé	Groupes, ressource, priorité de règle, posture et fraîcheur.
Autorisé mais application indisponible	Connecteur, DNS, destination/port, TLS et santé de l’application.
Fichiers lents	Trajet WAN, charge, pertes, débit et comportement du client lourd.
Accès conservé après retrait	Propagation, cache, jeton, session ZTNA et cookie applicatif.
Panne sur un seul chantier	Lien, DNS local, proxy, terminal, itinéraire et point d’accès.

Tableau de bord proposé

- Succès d’authentification et raisons de refus, sans confondre panne et blocage normal.
- Temps d’accès et opérations métier par site/application.
- Santé des connecteurs et réserve de capacité en panne.
- Retraits de droits, délai effectif de révocation et exceptions expirées.
- Logs reçus, signaux de posture récents et sauvegardes restaurées.

> **Ticket de support utile**
> Date/heure, identité non secrète, terminal, site, application, type d’erreur, règle et corrélation d’événement si disponibles. Ne pas joindre mot de passe, jeton, cookie ou contenu métier sensible.

Répartir les actions entre identité, terminal, réseau, ZTNA et application. Changer une règle d’autorisation pour masquer une panne réseau peut créer une faille.

13 — CAHIER DES CHARGES

Objet, périmètre et réception

Objet : concevoir, intégrer et mettre en exploitation un accès applicatif ZTNA pour les populations et applications validées, avec identité, posture, traçabilité, continuité et retour arrière.

Inclus par défaut dans l'étude	Options / exclusions à arbitrer
Accès applicatif privé, IdP/MFA, posture et publication.	SaaS, DLP/CASB, isolation et protection web avancée.
Connecteurs, droits, flux, audit, supervision et restauration.	Refonte générale WAN/LAN, annuaire ou applications.
Pilote, migration VPN limitée, formation et support.	OT critique, workloads et privilèges PAM sans étude dédiée.

Livrables attendus

- Inventaire, périmètre, architecture et matrice de flux.
- Matrice des politiques, rôles, identité, posture et exceptions.
- Dossier applicatif : protocoles, TLS, sessions et chemins alternatifs.
- Migration/rollback, runbooks, supervision, sauvegarde et PRA.
- 48 exigences renseignées, 22 tests et procès-verbal de recette.
- Contrat, licences, traitement des données, formation et réversibilité.

> **Priorités des 48 exigences**
> **P0** : bloquant avant mise en production. **P1** : nécessaire, avec échéance approuvée. **P2** : option ou évolution. Toute exigence conditionnelle doit être marquée applicable ou exclue formellement, avec justification.

Chaque ligne EX-01 à EX-48 contient un critère et un ou plusieurs tests T01 à T22. Toute réserve indique impact, compensation, responsable et date. Aucun test n'a été exécuté pour ce document.

13 — CAHIER DES CHARGES / LOT 1

Exigences : Identité et autorisations

Les cibles et l'applicabilité sont à figer au cadrage. Chaque critère doit recevoir une preuve dans les tests T01–T22, pages 38–39.

ID / priorité	Exigence	Critère d'acceptation	Tests
EX-01 **P0**	Fédérer les identités et tracer l'authentification.	IdP, groupes et SSO valides ; cas inconnu refusé.	T01
EX-02 **P0**	Imposer une MFA adaptée au risque.	Niveau vérifié, résistance au hameçonnage selon design ; pas de bypass.	T02
EX-03 **P0**	Approuver groupes et droits par ressource.	Groupe autorisé accepté ; autre groupe refusé.	T03
EX-04 **P0**	Limiter l'accès aux applications nécessaires.	Aucune autre destination ou fonction autorisée par défaut.	T03/T15
EX-05 **P0**	Limiter les comptes partenaires dans le temps.	Sponsor, cible, durée et retrait prouvés.	T04
EX-06 **P0**	Révoquer les accès après retrait d'identité/droit.	Délai de blocage et sessions réellement mesurés.	T05
EX-07 **P1**	Traiter séparément identités non humaines.	Mécanisme supporté, secrets tournants ; inclusion ou exclusion approuvée.	T14
EX-08 **P0**	Séparer administration et accès ordinaires.	Identités dédiées, privilèges ciblés et secours contrôlé.	T14

Validation
L'équipe projet fournit les résultats ; le propriétaire de service et les équipes concernées valident. Une capture de console ou un argument commercial ne suffit pas à prouver compatibilité, sécurité et reprise.

« Hors périmètre » exige une justification et une approbation, particulièrement pour SaaS, BYOD, DLP, PAM, OT, workloads et protocoles hérités.

13 — CAHIER DES CHARGES / LOT 2

Exigences : Posture et modes d’accès

Les cibles et l’applicabilité sont à figer au cadrage. Chaque critère doit recevoir une preuve dans les tests T01–T22, pages 38–39.

ID / priorité	Exigence	Critère d’acceptation	Tests
EX-09 **P0**	Vérifier l’état du terminal géré.	Conformité MDM/OS mesurée selon référence approuvée.	T06
EX-10 **P0**	Utiliser la santé EDR si le design l’exige.	Source, état et horodatage fiables ; signal positif testé.	T06
EX-11 **P0**	Traiter inconnu et signal périmé explicitement.	Aucune acceptation indéfinie d’un ancien état conforme.	T07
EX-12 **P0**	Refuser la posture invalide ou limiter selon règle.	Cas négatif refusé ; exception datée et approuvée.	T07
EX-13 **P0**	Réévaluer et appliquer les événements supportés.	Délai de détection, propagation et retrait mesuré.	T05/T07
EX-14 **P1**	Définir le BYOD et le web sans agent.	Applications compatibles ; restrictions prouvées, limites visibles.	T08
EX-15 **P0**	Supporter les OS et déploiements retenus.	Agent/navigateur, MDM, conflits VPN/proxy et mises à jour testés.	T06/T08
EX-16 **P0**	Minimiser les données de posture collectées.	Champs, finalité, accès et durée validés.	T13

Validation
L’équipe projet fournit les résultats ; le propriétaire de service et les équipes concernées valident. Une capture de console ou un argument commercial ne suffit pas à prouver compatibilité, sécurité et reprise.

« Hors périmètre » exige une justification et une approbation, particulièrement pour SaaS, BYOD, DLP, PAM, OT, workloads et protocoles hérités.

13 — CAHIER DES CHARGES / LOT 3

Exigences : Applications et connecteurs

Les cibles et l'applicabilité sont à figer au cadrage. Chaque critère doit recevoir une preuve dans les tests T01–T22, pages 38–39.

ID / priorité	Exigence	Critère d'acceptation	Tests
EX-17 **P0**	Inventorier chaque application du périmètre.	Propriétaire, protocoles, dépendances et recette connus.	T09/T10
EX-18 **P0**	Placer les connecteurs dans les zones prévues.	Cibles, rôle, capacité et secours validés.	T09/T11
EX-19 **P0**	Restreindre destinations et ports publiés.	Ressource utile joignable ; cibles non requises refusées.	T03/T15
EX-20 **P0**	Assurer le fonctionnement des applications web.	SSO, cookies, redirects, WebSocket et fichiers selon usage testés.	T09
EX-21 **P1**	Vérifier les protocoles non web retenus.	TCP/UDP, flux retour et opérations métier conformes ou exception cadrée.	T10
EX-22 **P0**	Intégrer DNS et dépendances AD/IdP.	Résolution et authentification correctes sans boucle ni ouverture large.	T18
EX-23 **P1**	Délimiter les contrôles SaaS si inclus.	Trajet, identité et complément SSE/CASB documentés et testés.	T01/T08
EX-24 **P0**	Encadrer maintenance, PAM et OT.	Accès ciblé ; usages critiques exclus sans validation métier.	T04/T10

Validation
L'équipe projet fournit les résultats ; le propriétaire de service et les équipes concernées valident. Une capture de console ou un argument commercial ne suffit pas à prouver compatibilité, sécurité et reprise.

« Hors périmètre » exige une justification et une approbation, particulièrement pour SaaS, BYOD, DLP, PAM, OT, workloads et protocoles hérités.

13 — CAHIER DES CHARGES / LOT 4

Exigences : Sécurité et maîtrise des sessions

Les cibles et l'applicabilité sont à figer au cadrage. Chaque critère doit recevoir une preuve dans les tests T01–T22, pages 38–39.

ID / priorité	Exigence	Critère d'acceptation	Tests
EX-25 **P0**	Appliquer refus par défaut et priorité des règles.	Aucune règle valable = refus ; conflit résolu comme approuvé.	T03
EX-26 **P0**	Documenter et sécuriser les segments TLS.	FQDN, chaîne, confiance et terminaison/déchiffrement validés.	T09
EX-27 **P0**	Durcir et limiter les connecteurs.	Gestion restreinte, flux approuvés et pas d'accès réseau général.	T09/T15
EX-28 **P0**	Maîtriser les chemins hors ZTNA.	Accès direct, public, local et VPN résiduel refusés ou équivalents contrôlés.	T15
EX-29 **P0**	Prendre en compte sessions et cookies applicatifs.	Retrait d'accès testé sur sessions actives et réouverture.	T05
EX-30 **P2**	Protéger les sorties de données si option retenue.	Contrôles applicatifs/DLP/CASB testés ; limites explicitement acceptées.	T17
EX-31 **P0**	Protéger et renouveler secrets/certificats.	Coffre, droits, rotation, expiration et API sans secrets exposés.	T14/T22
EX-32 **P0**	Auditer accès administratifs et changements.	Auteur, heure, objet, règle et résultat retrouvables.	T13/T14

Validation
L'équipe projet fournit les résultats ; le propriétaire de service et les équipes concernées valident. Une capture de console ou un argument commercial ne suffit pas à prouver compatibilité, sécurité et reprise.

« Hors périmètre » exige une justification et une approbation, particulièrement pour SaaS, BYOD, DLP, PAM, OT, workloads et protocoles hérités.

13 — CAHIER DES CHARGES / LOT 5

Exigences : Continuité et observabilité

Les cibles et l'applicabilité sont à figer au cadrage. Chaque critère doit recevoir une preuve dans les tests T01–T22, pages 38–39.

ID / priorité	Exigence	Critère d'acceptation	Tests
EX-33 **P0**	Redonder composants selon criticité.	Panne d'un connecteur/point d'accès ; capacité survivante prouvée.	T11
EX-34 **P0**	Définir la panne IdP et contrôle cloud.	Nouveaux accès/sessions/cache testés ; pas de fail-open général.	T12
EX-35 **P0**	Valider la continuité des chantiers.	WAN perdu/secours et usages locaux/distants mesurés.	T12
EX-36 **P0**	Dimensionner charge, protocoles et croissance.	Pointes, flux, fichiers et mode dégradé conformes au profil.	T16
EX-37 **P0**	Définir et mesurer les objectifs de service.	Disponibilité, performances et délai de révocation selon protocole.	T05/T16/T21
EX-38 **P0**	Collecter les logs utiles vers le SIEM.	Format, corrélation, horodatage, accès et conservation validés.	T13
EX-39 **P0**	Déclencher alertes et escalades exploitables.	Alerte de panne reçue et prise en charge avec runbook.	T21
EX-40 **P0**	Sauvegarder et restaurer règles/configuration.	RTO/RPO mesurés ; intégrité et dépendances vérifiées.	T20

Validation
L'équipe projet fournit les résultats ; le propriétaire de service et les équipes concernées valident. Une capture de console ou un argument commercial ne suffit pas à prouver compatibilité, sécurité et reprise.

« Hors périmètre » exige une justification et une approbation, particulièrement pour SaaS, BYOD, DLP, PAM, OT, workloads et protocoles hérités.

13 — CAHIER DES CHARGES / LOT 6

Exigences : Projet, intégrations et support

Les cibles et l'applicabilité sont à figer au cadrage. Chaque critère doit recevoir une preuve dans les tests T01–T22, pages 38–39.

ID / priorité	Exigence	Critère d'acceptation	Tests
EX-41 **P0**	Piloter chaque famille d'application.	Inventaire, compatibilité et migration testés avant généralisation.	T09/T10/T19
EX-42 **P1**	Relier droits et cycle de vie au workflow.	Demande, approbation, expiration et retrait traçables.	T04/T22
EX-43 **P0**	Préparer coexistence VPN et rollback limité.	Aucune ouverture globale réintroduite ; retour arrière testé.	T19
EX-44 **P1**	Automatiser avec une API supportée.	Droits minimaux, idempotence, erreurs et secrets contrôlés.	T22
EX-45 **P0**	Préparer mises à jour et retour de version.	Versions supportées, authenticité et procédure de reprise validées.	T20/T22
EX-46 **P0**	Former et transférer l'exploitation.	RACI, runbooks, support local et exercice incident acceptés.	T21
EX-47 **P0**	Valider contrats, licences et données.	Capacité, responsabilités, localisation, support et sous-traitance documentés.	T22
EX-48 **P0**	Livrer recette, réversibilité et acceptation.	48 exigences tracées, preuves/export et réserves signés.	T20/T22

Validation
L'équipe projet fournit les résultats ; le propriétaire de service et les équipes concernées valident. Une capture de console ou un argument commercial ne suffit pas à prouver compatibilité, sécurité et reprise.

« Hors périmètre » exige une justification et une approbation, particulièrement pour SaaS, BYOD, DLP, PAM, OT, workloads et protocoles hérités.

14 — PLAN DE RECETTE

Tests T01 à T11 : accès et applications

Test	Objet	Scénario	Critère attendu
T01	Identité / SSO	Compte valide, inconnu et SaaS si inclus.	IdP/groupes corrects ; accès inconnu refusé.
T02	MFA	Méthode et niveau requis, sans contournement.	Force et step-up conformes au design.
T03	Autorisations	Groupes, ressources, règle en conflit et cas sans règle.	Accès précis ; refus par défaut et bonne priorité.
T04	Partenaire / PAM	Sponsor, échéance, cible, privilège et retrait.	Durée/droits limités ; pas de réseau technique ouvert.
T05	Révocation	Retirer droit/compte ; tester session et cookie actifs.	Délai total mesuré ; réouverture interdite.
T06	Poste conforme	MDM, OS, EDR, agent et coexistence client.	Signal récent ; accès autorisé et stable.
T07	Posture négative	Invalide, inconnu, périmé puis changement en session.	Refus/limitation prévu ; délai documenté.
T08	BYOD / navigateur	Web sans agent et SaaS si inclus ; restrictions réelles.	Compatibilité et limites acceptées, aucun droit indu.
T09	Publication web	DNS, TLS, SSO, en-têtes, cookies et fonctions métier.	Chemin sûr, dépendances et opérations valides.
T10	Protocoles / OT	Client lourd, flux, fichiers ; PAM/OT uniquement si validés.	Support réel prouvé ou exception exclue/cadrée.
T11	Redondance	Perte d’un connecteur ou point d’accès du labo.	Reprise, RTO et capacité survivante validés.

Aucun test déjà exécuté
Chaque fiche doit indiquer date, site, version, exécutant, préconditions, résultat réel, preuve, durée et anomalie. Les critères sont attendus ; ne pas les présenter comme des mesures de production.

14 — PLAN DE RECETTE

Tests T12 à T22 : panne, exploitation et projet

Test	Objet	Scénario	Critère attendu
T12	Pannes dépendances	WAN, IdP/cloud et posture ; accès nouveaux/existants.	Mode documenté ; pas de fail-open ; retour contrôlé.
T13	Logs / données	Décision et changement, collecte SIEM, posture privée.	Traces utiles, temps, accès et conservation validés.
T14	Privilèges / secrets	Administration, identité non humaine, secours et certificat.	Moindre privilège, rotation et scope approuvés.
T15	Chemins alternatifs	Accès direct/public/local et VPN ; cible non publiée.	Aucun contournement des exigences d’accès.
T16	Charge métier	Sessions/flux, fichiers BIM et nœud survivant.	Débit/temps conformes au profil mesuré.
T17	Sortie de données	Cas bénin de téléchargement/partage si contrôle retenu.	Restriction prouvée et limites acceptées.
T18	DNS / AD	FQDN, vues, résolution client/connecteur et dépendances.	Résultat cohérent ; pas de fuite ou d’ouverture large.
T19	Migration / VPN	Bascule pilote, coexistence puis retour arrière.	Fonctions métier, droits et segmentation préservés.
T20	Restore / sortie	Restauration isolée, export, version et dépendances.	RTO/RPO, données et réversibilité démontrés.
T21	Exploitation	Sondes, alerte, incident, formation et escalade.	Service mesuré ; runbooks et support acceptés.
T22	Workflow / réception	API relancée/erreur, upgrades, contrats et dossiers.	Idempotence, sécurité, versions et PV validés.

Règle de réception
Les P0 applicables doivent réussir ou faire l’objet d’une décision formelle de report/réserve. Les essais intrusifs/destructifs restent limités à un environnement ou une fenêtre autorisée, avec retour arrière.

15 — ATELIER ET DIAGNOSTIC

Un exemple de politique, sans fournisseur imposé

Laboratoire fictif : compte salarié CH-042, poste conforme, GED en HTTPS. Préparer aussi un compte d'un autre projet et un poste à signal périmé pour démontrer les refus.

```
# PSEUDO-YAML PEDAGOGIQUE : aucune syntaxe fournisseur
resource: GED-CH042
match:
  group: PROJET-CH042-SALARIES
  identity_active: true
  mfa_level: approved
  device: managed_and_compliant
  posture_fresh: true
access:
  destination: ged.ch042.construction.example
  protocol: HTTPS
  port: 443
otherwise: deny
# Priorites, TTL et revocation a definir dans le produit
```

Déroulé de démonstration

1. Montrer l'accès du salarié autorisé et la trace de la décision.

2. Montrer le refus d'un autre groupe ou d'une posture invalide.

3. Retirer le droit du laboratoire et mesurer session ZTNA puis session applicative.

4. Tester un accès direct à l'origine, uniquement dans le périmètre de test autorisé.

Contrôles client non destructifs

```
# PowerShell : informations reseau et resolution
Get-NetIPConfiguration
Resolve-DnsName ged.ch042.construction.example
# Linux : resolution DNS classique si c'est le mode retenu
dig ged.ch042.construction.example
```

Selon le produit, la résolution peut être interceptée ou synthétique : interpréter les résultats avec l'architecture. Recueillir les événements IdP, posture, règle, connecteur et application, sans afficher jeton, cookie ou secret.

16 — RISQUES

Registre initial et questions fournisseur

Risque	Impact possible	Mesure / validateur
Règle trop large	Accès hors projet ou latéral.	Cibles précises et T03/T15 — sécurité.
Signal posture périmé	Terminal dangereux accepté.	Fraîcheur et T07 — MDM/EDR.
Session non révoquée	Accès conservé après départ.	Mesure totale T05 — IAM/applications.
Chemin direct ou VPN	Contournement du ZTNA.	Filtrage et T15/T19 — réseau.
Protocole incompatible	Client métier inutilisable.	Inventaire et T10 — métiers.
IdP/WAN indisponible	Accès bloqué ou exception risquée.	Résilience et T12 — infrastructure.
Connecteur compromis	Zone applicative exposée.	Durcissement/scope — exploitation.
Inspection ou collecte excessive	Données sensibles exposées.	Flux, contrats, minimisation — RSSI/DPO.
Dépendance fournisseur	Sortie difficile ou coûteuse.	Export et T20 — achats/DSI.

À demander en consultation

- Support exact OS/protocoles, sessions et réévaluation ; preuves en panne.
- Localisation des contrôles, du trafic déchiffré et des journaux.
- Limites des connecteurs, fréquence posture, API, SLA et licences.
- Conditions de support, upgrades, réversibilité et responsabilités.

> **Priorité métier**
> Classer probabilité et impact avec les responsables réels. Ne pas qualifier un site « critique » ou un risque « faible » sans connaître ses usages et dépendances.

16 — BUDGET ET SÉLECTION

Coût total, options et gains mesurés

Poste de coût	À demander dans un devis
Licences / abonnement	Identités, utilisateurs, terminaux, apps, connexions ou autres métriques exactes.
Hébergement / accès	Connecteurs, VM, réseau, cloud, liens de secours et stockage.
Compléments	IdP/MFA, posture, PAM, DLP/CASB, isolation et reporting.
Projet	Inventaire, migration, intégration, tests, formation et documentation.
Exploitation / évolution	Temps interne, support, upgrades, certificats et croissance.
Sortie	Export, transition, double exploitation et retrait des composants.

TCO : coûts initiaux + récurrents + effort interne + évolution + sortie, sur une période définie. Aucun tarif actuel n'a été vérifié. Comparer des offres sur le même périmètre et les mêmes tests.

Critère de choix	Preuve utile
Couverture métier	T09/T10 et opérations lourdes réellement utilisables.
Sécurité	T03/T05/T07/T15 et résultats de refus/révocation.
Résilience	T11/T12/T16/T20 avec dépendances incluses.
Exploitation / données	T13/T21/T22, contrat et dossier de responsabilités.

Exemple de gain à confirmer
Si 100 accès partenaires par mois passent de 30 à 12 minutes de traitement, le gain théorique est **100 × 18 / 60 = 30 heures par mois**. Mesurer approbation, incidents, exceptions et effort de support avant de valoriser ce résultat.

Ne pas compter comme économie tout le coût du VPN s'il reste nécessaire pour une partie des applications. Les gains de ZTNA dépendent du design et du changement des pratiques.

17 — LEXIQUE ET REPÈRES

Vocabulaire et références officielles à consulter

Terme	Définition utile
ZTNA / Zero Trust	Accès applicatif contrôlé / stratégie globale sans confiance implicite.
IdP / IAM / MFA	Fournisseur d'identité / gestion des identités / authentification multifacteur.
PDP / PEP	Point de décision / point qui applique la décision.
Posture / MDM / EDR	État terminal / gestion du parc / détection et protection du poste.
Connecteur	Composant reliant certaines applications privées au chemin d'accès.
SSE / SASE	Services de sécurité d'accès / association réseau et sécurité distribuée.
PAM / DLP / CASB	Privilèges / protection contre fuite / contrôle d'usages cloud.
SSO / jeton / session	Connexion fédérée / preuve avec durée / état d'accès à gérer.
RTO / RPO / p95	Délai de reprise / perte tolérée / percentile 95 d'une mesure.

Repères stables, pas vérification commerciale

- **NIST SP 800-207 — Zero Trust Architecture** : modèle, décisions et points d'application. Repère : csrc.nist.gov/pubs/sp/800/207/final.
- **CISA — Zero Trust Maturity Model** : identité, appareils, réseau, applications et données. Repère : cisa.gov/zero-trust-maturity-model.
- **ANSSI** : recommandations d'authentification, accès nomade et administration sécurisée à sélectionner selon le contexte. Repère : cyber.gouv.fr.
- **Documentation retenue** : IdP, MDM/EDR, ZTNA, PAM et applications ; matrices OS/protocoles, ports, versions, session et licences.

> **Limite de vérification**
> Ces repères n'ont pas été consultés en ligne lors de la génération. Revalider les recommandations, contrats et offres applicables. Ce dossier n'est ni une documentation éditeur, ni une certification, ni un audit du SI réel.

FICHE DE PRÉSENTATION — PRÊTE À UTILISER

Expliquer un environnement ZTNA en cinq minutes

1 · Le problème métier

« Salariés et partenaires doivent accéder aux applications depuis le siège, chez eux ou sur un chantier. Donner un accès réseau trop large augmente les risques et complique le retrait des droits. »

2 · La réponse ZTNA

« On contrôle l'identité, la conformité du poste et le besoin. On ouvre la seule application autorisée, avec une durée et des règles définies, sans supposer que la personne est de confiance parce qu'elle est connectée au réseau. »

3 · L'exemple du projet

« La collaboratrice CH-042 peut ouvrir la GED de son projet avec MFA depuis un poste conforme. Un partenaire reçoit un accès limité et expirant. Aucun des deux ne doit accéder automatiquement aux autres projets ou au réseau technique. »

4 · Les limites à assumer

« Le ZTNA ne remplace pas les permissions applicatives, l'EDR ou le WAN. Tous les protocoles ne sont pas forcément supportés, et la révocation des sessions doit être testée. La continuité du chantier nécessite une architecture adaptée. »

5 · La décision raisonnable

« Inventorions les usages, lançons un pilote représentatif et mesurons sécurité, compatibilité, performance et reprise. Les 48 exigences et 22 tests permettront une décision sur preuves, pas sur une promesse commerciale. »

> **Trois décisions pour lancer l'étude**
> **1.** Nommer sponsor, service et propriétaires d'applications.
> **2.** Choisir le pilote, les besoins WAN et les populations.
> **3.** Valider exigences, identité, posture, données et recette.

Étude adaptée au contexte d'une entreprise comme Bouygues Construction ; aucune affirmation sur son fournisseur, son architecture réelle ou l'approbation de sa DSI.